

Wazuh как SIEM и XDR: Полное руководство по архитектуре, внедрению и боевым практикам

 redsec.by/article/wazuh-kak-siem-i-xdr-polnoe-rukovodstvo-po-arhitecture-vnedreniyu-i-boevym-praktikam

Средства защиты | 28 января 2026



В современной реальности кибербезопасность без централизованного логирования и мониторинга — это опасная иллюзия. Ежедневно на инфраструктуру любой компании обрушивается волна событий: попытки брутфорса, сканирование периметра, модификации критических файлов или аномальная активность пользователей внутри сети. Без системы, способной собрать этот хаос в единую картину, вы не увидите атаку до момента, когда ущерб станет необратимым.

SIEM (Security Information and Event Management) решает эту задачу. Но коммерческие решения вроде Splunk или ArcSight стоят целое состояние. Здесь на сцену выходит **Wazuh** — мощнейший Open Source инструмент, который при правильной настройке превращается в полноценный XDR.

В этом фундаментальном руководстве мы разберем Wazuh «по косточкам»: от архитектуры и развертывания до написания кастомных правил детекта и защиты самого SIEM.

Часть 1. Почему SIEM — это необходимость, а не роскошь

Даже малый бизнес с 50 сотрудниками сегодня обязан иметь минимальный SIEM. Это больше не прихоть энтерпрайза. Почему? Потому что **время обнаружения (Mean Time To Detect)** напрямую влияет на стоимость инцидента.

Битва подходов: Open-source (Wazuh) vs Enterprise (Splunk/Sentinel)

Выбор платформы — это первое стратегическое решение.

Плюсы коммерческих решений (Splunk, Microsoft Sentinel):

- Готовые интеграции «из коробки» (Click-to-run).
- Enterprise support и SLA.
- Управляемые сервисы (вашу безопасность мониторит вендор).

Почему выбирают Wazuh (Open-source):

- **Отсутствие Vendor Lock-in:** Вы владеете данными и кодом. Никто не отключит вам лицензию из-за санкций или смены политики.
- **Полная кастомизация:** Вы можете переписать любой декодер, правило или скрипт реагирования под специфику вашей инфраструктуры.
- **Прозрачность:** Вы видите каждую строку кода, отвечающую за вашу безопасность.
- **Низкая стоимость владения (TCO):** Вы платите только за «железо» (инфраструктуру). Никаких лицензий с оплатой за гигабайт логов.
- **Community-driven:** Активное сообщество быстрее реагирует на новые угрозы, выпуская правила детекта.

Есть и минусы: Open-source требует инженерной экспертизы. Здесь нет кнопки «Сделать безопасно», ответственность за настройку и аптайм лежит на вас.

Терминологический ликбез: SIEM, EDR или XDR?

Маркетинг часто смешивает эти понятия. Давайте определим место Wazuh на карте технологий. **Wazuh — это гибрид SIEM + EDR + XDR, но с оговорками.**

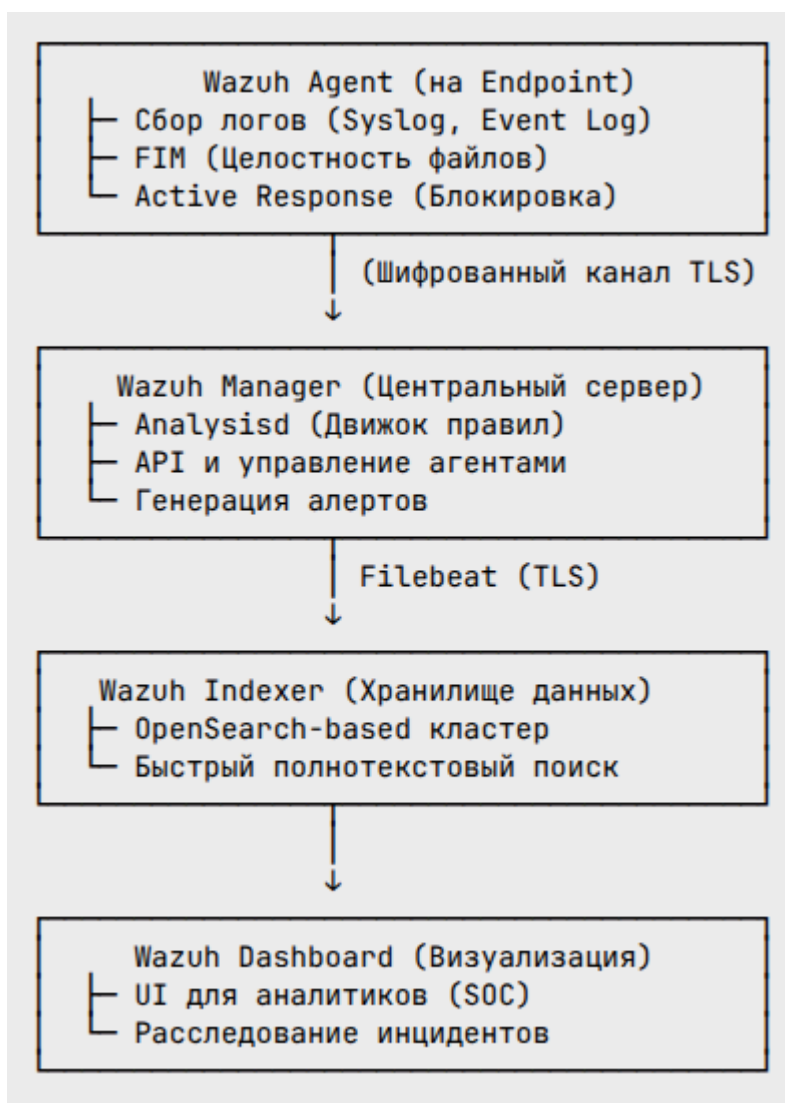
Компонент	Суть технологии	Реализация в Wazuh	Спец. решения (конкуренты)
SIEM	Сбор логов, нормализация, корреляция событий.	Полная поддержка. Это ядро Wazuh.	Splunk, Elastic, QRadar
EDR	Endpoint Detection & Response (мониторинг процессов, памяти).	Базовая. Есть FIM, inventory, но нет memory forensics.	CrowdStrike, MS Defender for Endpoint
XDR	Extended Detection (Endpoints + Network + Cloud).	Возможно. Требуется настройки интеграций с сетью и облаками.	Palo Alto Cortex
SOAR	Оркестрация и автоматизация реагирования.	Нет. Только вебхуки для запуска внешних систем.	Shuffle, TheHive

Вердикт: Wazuh идеален как основной SIEM и первый эшелон EDR для компаний любого размера. Для полноценного Enterprise-уровня его часто усиливают внешними Threat Intel платформами и SOAR-системами.

Часть 2. Архитектура Wazuh: Взгляд изнутри

Понимание архитектуры критически важно для производительности и масштабируемости. Система состоит из четырех ключевых компонентов.

Схема взаимодействия



1. Wazuh Agent: «Глаза и руки»

Устанавливается на конечные точки (Windows, Linux, macOS).

- **Функции:** Читает локальные логи, следит за изменениями файлов (FIM), проводит инвентаризацию ПО и выполняет команды активного реагирования.
- **Безопасность:** Не хранит логи локально (защита от кражи данных при физическом доступе), передает данные по TLS.

2. Wazuh Manager: «Мозг»

Серверная часть, где происходит магия анализа.

- **Analysisd:** Движок корреляции. Именно здесь сырой лог превращается в алерт.
- **Хранение:** Менеджер временно хранит алерты в сжатом виде (.json.gz) перед отправкой в индексатор.

3. Wazuh Indexer: «Память»

Форк Elasticsearch (OpenSearch).

- Обеспечивает индексацию и поиск по алертам в режиме near-real-time (задержка ~1 сек).
- Поддерживает кластеризацию для отказоустойчивости (High Availability).

4. Wazuh Dashboard: «Интерфейс»

Веб-интерфейс на базе OpenSearch Dashboards для работы аналитиков SOC, визуализации данных и управления конфигурациями.

Часть 3. Функциональные возможности: Что умеет система

Wazuh — это комбайн. Чтобы использовать его эффективно, нужно понимать каждый модуль.

3.1 Сбор и нормализация логов

Wazuh умеет работать с огромным спектром источников:

- **Windows Event Log:** Нативно, без лишних "костылей".
- **Syslog (Linux, Network devices):** Стандарт де-факто.
- **Application logs:** Nginx, Apache, MySQL и другие.
- **Cloud:** AWS CloudTrail, Azure Audit (через API).

Магия нормализации:

Сырой лог (например, строка из Nginx) попадает в Wazuh, где *декодеры* разбирают его на поля. На выходе мы получаем структурированный JSON объект.

Было: Jan 20 10:42:33 web nginx: 192.168.1.10 GET /admin 403

Стало:

```
{
  "http": { "method": "GET", "uri": "/admin", "status": "403" },
  "srcip": "192.168.1.100"
}
```

Это позволяет писать правила вида: ЕСЛИ status == 403 И uri == /admin ТОГДА ALERT.

3.2 HIDS и Детектирование атак

Система правил Wazuh построена на иерархии уровней важности (от 0 до 15):

- **0-2:** Информационные события (не требуют реакции).
- **3-4:** Низкий риск.

- **5-8:** Средний и высокий риск (требуют внимания).
- **9-15:** Критические инциденты (взлом, малварь).

Встроенный набор правил покрывает MITRE ATT&CK матрицу, включая SSH brute force, повышение привилегий (sudo), обфусцированный PowerShell и многое другое.

3.3 File Integrity Monitoring (FIM)

Один из мощнейших модулей. Агент вычисляет хеши файлов в критических директориях и сверяет их с эталоном.

- **Кейс:** Загрузка веб-шелла в /var/www/html.
- **Кейс:** Изменение системного файла hosts или ключей реестра Windows.
- **Compliance:** Требование стандартов PCI DSS и GDPR.

3.4 Vulnerability Detection (Сканер уязвимостей)

Wazuh собирает список установленного ПО и сверяет версии с базами CVE (NVD, Microsoft, Canonical, RedHat).

- *Важно:* Наличие CVE не означает факт взлома. Это информация для патч-менеджмента.
- Модуль помогает приоритезировать обновления безопасности.

3.5 Active Response (Активное реагирование)

Автоматическая "ответка" на атаку.

- **Блокировка IP:** firewall-drop (iptables/netsh).
- **Изоляция хоста:** host-deny.
- **Кастомные скрипты:** Например, выключить скомпрометированного пользователя в AD.

Риск: Неправильно настроенный Active Response может привести к DoS вашей собственной инфраструктуры. Всегда тестируйте в режиме dry-run!

Часть 4. Источники логов: Стратегия подключения

Типичная ошибка новичка — подключить все подряд или, наоборот, забыть главное. Если у вас нет логов, SIEM слеп.

Матрица критичности источников

Источник	Критичность	Что ловим
Критично	Вход в систему, создание учеток, повышение прав.	
DNS Server	Критично	Связь с C2 серверами, туннелирование, малварь.
Firewall	Критично	Сканирование портов, дропы, аномальные соединения.
VPN Gateway	Критично	Кто и откуда заходит во внутреннюю сеть.
Web Server / Proxy	Высокая	Атаки на веб-приложения (SQLi, XSS, RCE).
Endpoints (Workstations)	Средняя	Локальные процессы, USB, PowerShell.

Важный вывод: SIEM без логов контроллера домена и DNS — это просто красивая карта мира на стене. Вы не увидите ни авторизации, ни перемещения злоумышленника (Lateral Movement).

План подключения:

- **Неделя 1:** DC + DNS (ядро сети).
- **Неделя 2:** Периметр (Firewall, VPN).
- **Неделя 3:** Бизнес-приложения (Web, Databases).

Часть 5. План внедрения: От PoC до Production

Внедрение SIEM — это проект, а не установка софта.

Этап 1: PoC (Proof of Concept) — 2 недели

Цель: Доказать работоспособность.

- Развернуть «All-in-one» инсталляцию.
- Подключить 5-10 тестовых агентов.
- Продемонстрировать 3 кейса: SSH брутфорс, FIM (создание файла), детект уязвимости.

Этап 2: Пилот — 1-2 месяца

Цель: Тюнинг и борьба с шумом.

- Масштабирование до 50-200 хостов.
- **Baseline:** Сбор всех алертов за неделю для анализа нормального поведения.
- **Tuning:** Отключение false positive правил (уровень 0). Если вы этого не сделаете, аналитики "выгорят" от тысяч ложных уведомлений.
- Настройка уведомлений (Slack/Telegram).

Этап 3: Production — Постоянный процесс

- Разнесение ролей (кластер Indexer, отдельный Manager).
- Настройка политик хранения (Retention policy 90+ дней).
- Регламенты реагирования (Runbooks) для SOC.

Часть 6. Стратегия детектов и подавление шума

Главный враг SIEM — **False Positive Fatigue** (Усталость от ложных срабатываний). Если система шлет 10,000 алертов в день, на реальный взлом никто не обратит внимания.

Методика настройки правил

- **Базовый уровень:** Оставьте включенными правила уровня 7+ (высокий риск).
- **Подавление (Suppress):** Если правило срабатывает на легитимное действие (например, админ запускает сканер сети), создайте исключение.

Пример правила подавления (Custom Rule):

Задача: Игнорировать FIM алерты, если файлы меняет Windows Defender.

```
<group name="local,">
  <rule id="100001" level="0">
    <if_sid>92213</if_sid>  <!-- ID правила изменения файла -->
    <field name="data.win.eventdata.targetFilename">C:\\ProgramData\\Microsoft\\Win
    <description>Ignore Windows Defender files modification</description>
  </rule>
</group>
```

Частотные пороги (Frequency): Не нужно алертить на *каждую* неудачную попытку входа. Алертите, если их 10 за 2 минуты.

```
<rule id="100002" level="5">
  <if_sid>5712</if_sid>  <!-- SSH brute force -->
  <frequency>10</frequency>
  <timeframe>120</timeframe>
  <description>SSH Brute Force - 10+ attempts in 120 seconds</description>
</rule>
```


Часть 7. Боевые Use-Cases: 15 сценариев детекта

В этом разделе мы рассмотрим конкретные примеры правил для обнаружения реальных атак. Это "мясо" вашей системы безопасности.

Use Case 1: SSH Brute Force с авто-блокировкой

- **Источник:** Linux syslog.
- **Логика:** 10 попыток за 2 минуты -> Alert -> Firewall Drop.

Use Case 2: Windows Privilege Escalation (UAC Bypass)

Злоумышленники часто используют PowerShell для обхода защиты.

```
<rule id="100003" level="7">
  <if_sid>60104</if_sid>  <!-- Process creation -->
  <field name="data.win.eventdata.image">.*powershell.exe</field>
  <field name="data.win.eventdata.commandLine">NoProfile.*ExecutionPolicy.*Bypass</f
  <description>Suspicious PowerShell execution with bypass parameters</description>
</rule>
```

Use Case 3: Атака на AD — DCSync (Mimikatz)

Попытка выгрузить хеши паролей всех пользователей домена. Критичнейший инцидент.

```
<rule id="100004" level="10">
  <if_sid>60103</if_sid>
  <field name="data.win.system.eventID">^4662$</field>
  <field name="data.win.eventdata.objectName">.*NTDS</field>
  <description>Possible DCSync attack - NTDS.dit access detected</description>
</rule>
```

Use Case 4: Web Shell Upload

Детект появления PHP-шелла в папке веб-сервера через FIM + интеграция с YARA.

Результат: Alert level 8 + отчет YARA о типе малвари.

Use Case 5: Ransomware (Подозрительная активность)

Шифровальщики часто запускают утилиты для удаления теневых копий.

```
<rule id="100006" level="7">
  <if_sid>60104</if_sid>
  <field name="data.win.eventdata.image">.*\\TEMP\\.*</field>
  <field name="data.win.eventdata.commandLine">vssadmin|wmic|bcdedit|fsutil</field>
  <description>Possible ransomware - suspicious process from TEMP</description>
</rule>
```

Use Case 6: Lateral Movement (PsExec)

Перемещение внутри сети с использованием PsExec.

```
<rule id="100007" level="8">
  <if_sid>60104</if_sid>
  <field name="data.win.eventdata.commandLine">.*psexec.*</field>
  <description>Lateral movement - PsExec execution detected</description>
</rule>
```

Use Case 7: Создание скрытого админа

```
<rule id="100008" level="6">
  <if_sid>60101</if_sid>
  <field name="data.win.system.eventID">^4720$</field> <!-- User Created -->
  <field name="data.win.eventdata.privilegeList">.*Administrator</field>
  <description>Suspicious account creation - possible backdoor</description>
</rule>
```

Use Case 8: DNS Tunneling

Вывод данных через длинные DNS-запросы.

```
<rule id="100009" level="6">
  <if_sid>1224</if_sid>
  <regex>^[a-z0-9]{50,}\.malicious\.domain$</regex>
  <description>Possible DNS tunneling - unusually long subdomain</description>
</rule>
```

Use Case 9: Изменение конфигов веб-сервера (Persistence)

Мониторинг /etc/nginx/nginx.conf через FIM в реальном времени.

Use Case 10: Создание задач в планировщике (Scheduled Task)

Любимый способ закрепления хакеров.

```
<rule id="100010" level="5">
  <if_sid>60101</if_sid>
  <field name="data.win.system.eventID">^4698$</field>
  <field name="data.win.eventdata.taskName">.*\\Microsoft\\Windows\\UPnP</field>
  <description>Scheduled task created in suspicious location</description>
</rule>
```

Use Case 11: Установка сервиса из папки TEMP

Классика малвари.

```
<rule id="100011" level="6">
  <if_sid>60101</if_sid>
  <field name="data.win.system.eventID">^7045$</field>
```

```
<field name="data.win.eventdata.imagePath">.*\\TEMP\\</field>
<description>Service installed from TEMP directory</description>
</rule>
```

Use Case 12: Аномальные исходящие соединения (C2)

Подключение к нестандартным портам (4444, 6666) на внешние IP.

```
<rule id="100012" level="5">
  <if_sid>61603</if_sid>
  <field name="data.win.eventdata.destinationPort">^4444$|^5555$|^6666$</field>
  <field name="data.win.eventdata.destinationIp" negate="yes">^(10\.|172\.|192\.168\
  <description>Suspicious outbound connection to non-standard port</description>
</rule>
```

Use Case 13: Credential Dumping (Mimikatz keywords)

Поиск в командной строке ключевых слов sekurlsa или lsadump.

Use Case 14: Отключение защиты (Registry Modification)

Малварь отключает Windows Defender через реестр.

```
<rule id="100014" level="7">
  <if_sid>61607</if_sid>
  <field name="data.win.eventdata.targetObject">.*DisableRealtimeMonitoring</field>
  <field name="data.win.eventdata.details">0x00000001</field>
  <description>Windows Defender real-time protection disabled</description>
</rule>
```

Use Case 15: Успешный брутфорс

Много неудачных попыток, за которыми сразу следует удачная. Это значит, пароль подобран.

```
<rule id="100015" level="8">
  <if_sid>5512</if_sid>
  <frequency>10</frequency>
  <timeframe>300</timeframe>
  <group_by>data.win.eventdata.targetUserName</group_by>
  <description>Multiple failed logons followed by successful login</description>
</rule>
```

Часть 8. Интеграции и автоматизация

SIEM не должен быть островом. Он должен общаться с внешним миром.

Уведомления (Slack/Telegram/Email)

Wazuh из коробки поддерживает отправку алертов. **Пример конфига для Slack:**

```
<integration>
  <name>slack</name>
  <hook_url>https://hooks.slack.com/services/YOUR/WEBHOOK</hook_url>
  <level>7</level> <!-- Отправлять только важные -->
  <alert_format>json</alert_format>
</integration>
```

Обогащение данных (Threat Intelligence)

Интеграция с **VirusTotal**. Когда FIM находит новый файл, Wazuh отправляет его хеш в VirusTotal. Если репутация файла плохая, алерт обогащается этими данными, и его уровень повышается.

SOAR (Shuffle / TheHive)

Wazuh не умеет строить сложные цепочки реагирования (Playbooks). Для этого используют Shuffle. Wazuh шлет вебхук в Shuffle, а тот уже создает тикет в Jira, блокирует пользователя в AD и шлет SMS CISO.

Часть 9. Hardening: Защита самого SIEM

SIEM — это цель №1 для хакера. Захватив Wazuh, атакующий может замести следы, удалить логи или даже использовать механизм Active Response для распространения малвари на все агенты.

Чек-лист безопасности Wazuh:

- **Сегментация сети:** Wazuh Manager и Indexer должны быть в отдельной Management VLAN. Доступ к Dashboard только через VPN или бастион.
- **Шифрование:** Включите TLS для всех соединений (Agent-Manager, Filebeat-Indexer, HTTPs для Dashboard). Используйте клиентские сертификаты.
- **Аутентификация:** Настройте LDAP/AD интеграцию для доступа в Dashboard. Включите MFA.
- **Резервное копирование:**
 - Снэпшоты Indexer — ежедневно.
 - Бэкап конфигов Manager — еженедельно.
 - Храните бэкапы на изолированном сторадже.
- **Самомониторинг:** Настройте алерты на падение сервисов Wazuh, переполнение диска или остановку поступления логов.

Часть 10. Производительность (Sizing)

Не ставьте Wazuh на слабые машины. Это база данных, которая постоянно пишет и читает.

Расчет ресурсов (Примерный APS - Alerts Per Second):

- 10-50 хостов: Single Node (4 vCPU, 8 GB RAM).
- 500 хостов: Distributed (Manager 8 vCPU/16GB, Indexer Cluster 3 nodes).
- 2000+ хостов: High-load Cluster (16+ vCPU, NVMe диски обязательны).

Формула места на диске (90 дней хранения):

$APS * 86400 \text{ (сек в сутках)} * 90 / 1000 = \text{GB}$ При 10 APS (активная сеть на ~200 хостов) вам понадобится около 80 ГБ только под индексы. Закладывайте x2 для запаса.

Часть 11. Топ ошибок при внедрении

Избегайте этих граблей, на которые наступают 90% новичков.

- **Включить все правила сразу.** Вы утонете в логах. Начинайте с малого.
- **Нет ответственных.** Если на алерты никто не реагирует, SIEM бесполезен.
- **Игнорирование DC и DNS.** Без этих логов вы слепы.
- **Single Node для Enterprise.** Когда база вырастет, один сервер не справится с индексацией и поиском.
- **Отсутствие бэкапов.** Индексы ломаются. Диски горят. Без бэкапа вы потеряете аудит за год.

Wazuh — это профессиональный инструмент, который дает SOC «глаза». Он позволяет видеть невидимое: от тихих изменений файлов до сложных атак на контроллер домена.

Однако, помните: **Wazuh — это инструмент, а не решение.**

- Он дает **видимость** (Detection).
- Ваша команда дает **интеллект** (Analysis & Tuning).
- Интеграции дают **реакцию** (Response).

Эффективность SIEM зависит не от софта, а от того, как вы выстроили процессы, настроили правила и работаете с инцидентами. Начните с PoC, двигайтесь итеративно, и ваша инфраструктура станет крепким орешком для злоумышленников.